



FUNDAMENTALS OF INFORMATION SECURITY

COURSE CODE:

CYBE 6123

LECTURER: **NGUEMETA NATHANIEL**

Introduction to Information Systems Security

- What unauthorized access and data breaches are
- What information systems security is
- What the tenets of information systems security are
- What the seven domains of an information technology (IT) infrastructure are
- What the weakest link in an IT infrastructure is
- How an IT security policy framework can reduce risk
- How a data classification standard affects an IT infrastructure's security needs

Prepare and pass the ISC2 **SSCP Exam**

Data and Information



- ***What is Data?***
- Data is a single or collection of bits and bytes in any format.
- ***What is information?***
- Information is considered as data that can be interpreted to provide meaningful knowledge.

Information Systems

- Composition of hardware, operating systems and software applications
- Stores, processes and transmits information
- Are most often interconnected and used to exchange information
- Cannot secure themselves
- Are sometimes outdated
- Sometimes becomes expensive to keep up with
- May require specialized skillset to maintain

The Cyberspace

- Multiple inter-connected systems
- Full of opportunities and challenges
- No single governance body or central authority
- Facilitates the anything-to-anything connectivity scenario
- Initiates the innovative idea of new frontiers between entities
- Struggles with weak communication protocol (TCP stack)

Frontiers of the Cyberspace

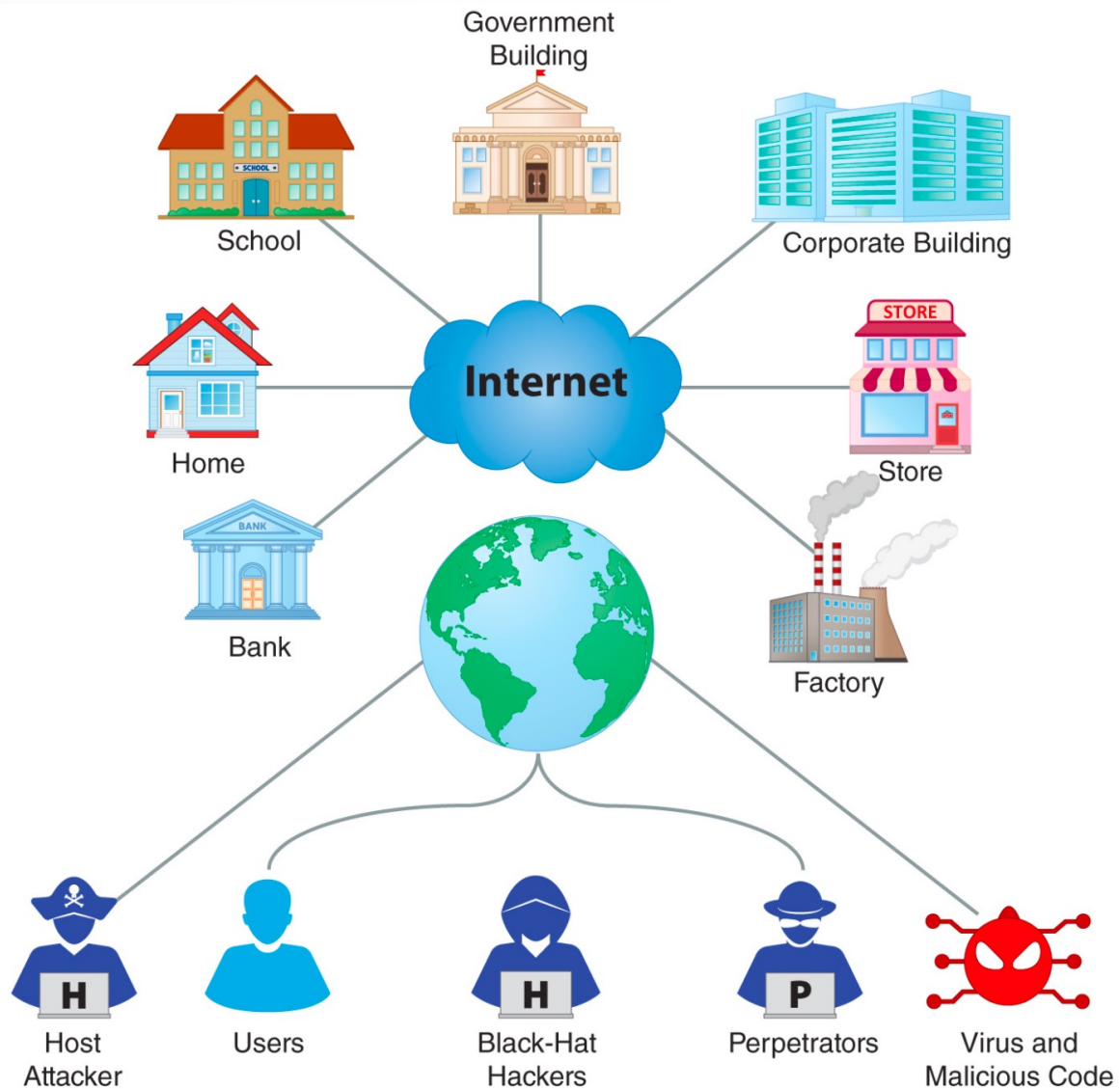
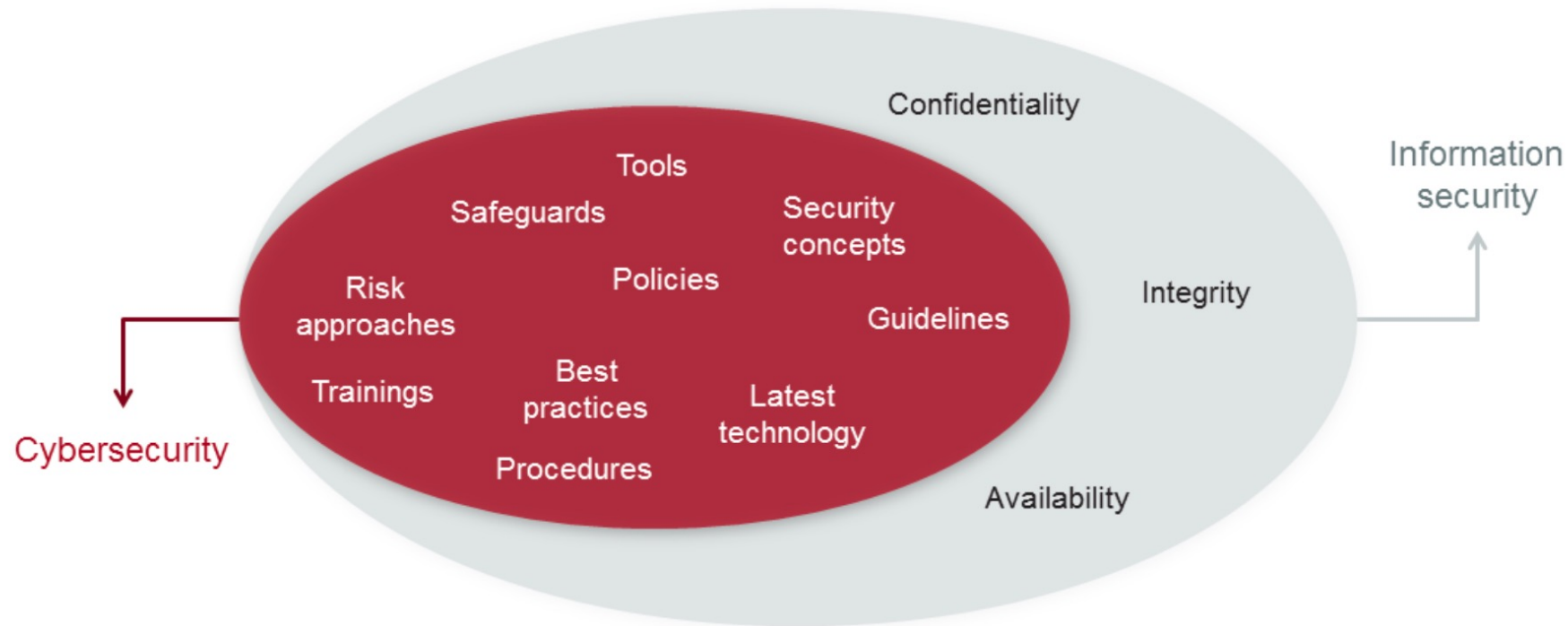


FIGURE 1-1 Cyberspace: The new frontier

Cybersecurity Vs Information Security

Difference between Information Security and Cybersecurity



Cybersecurity and Data Security



- Cybersecurity is the duty of any government that wish to protect its national security
 - *Involves active and passive activities aimed at ensuring the security of people and assets directly and/or indirectly linked to the cyberspace*
- Data security is the responsibility of every organization that needs to protect its information assets and sensitive data
 - *Involves proactive and reactive activities aimed at ensuring the security of sensitive information such as PII, PHI, PCI, Financial data etc...*
- Information security englobes both

Cybersecurity and IoT



- IoT facilitates the availability to access the internet from anywhere and on any device, sometimes easing mobility of users as well
- IoT increases the attack surface, and presents great challenge to cyber warriors due to huge number
- IoT brings along many diverse critical data into the cyberspace
- IoT devices requires many different protection mechanisms, some of which are not feasible

Risks, Threats, and Vulnerabilities

- **Risk** is the level of exposure to some event that has an effect on an asset, usually the likelihood that something bad will happen to an asset.
- A **threat** is any action, either natural or human induced, that could damage an asset.
- A **vulnerability** is a weakness that allows a threat to be realized or to have an effect on an asset.

Information Systems Security

- Interconnection of information systems opens them to new risks
- Cyber attacks have become increasingly alarming, with new breaches being announced every day
- Security needs to be applied at different levels of the data position to allow for maximum protection

Information Systems Security

is the collection of activities that protect the information system and the data stored in it.

Information Security

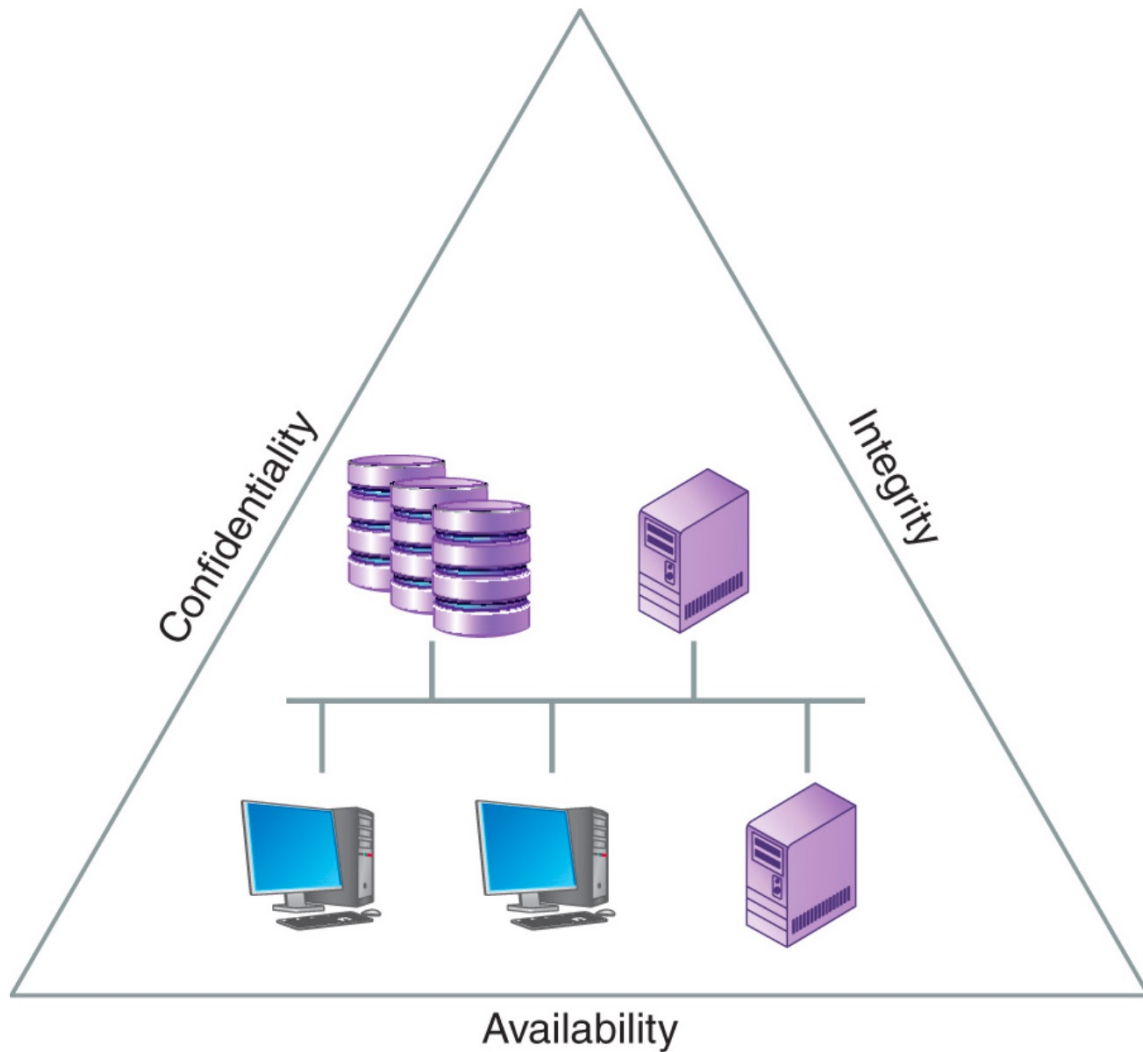


FIGURE 1-6 The three tenets of information systems security

- Secure information should satisfy three tenets, or properties:
- **Confidentiality**—Only authorized users can view information.
- **Integrity**—Only authorized users can change information.
- **Availability**—Information is accessible by authorized users whenever they request the information.

Security control



- Any mechanism or action that prevents, detects, or responds to an attack and thus reduces overall risk.
- Required by law to be implemented to address Information Security Risks
- Should match the level of risk being addressed
- Can be in any form (Administrative, Technical, Operational)

Confidentiality

- Confidentiality means guarding information from everyone except those with rights to it.
- Examples of confidential information:
 - Private data of individuals such as:
 - Personal Health Information or records (PHI)
 - Payment Card Information (PCI)
 - Personally Identifiable Information (PII)
 - Intellectual property of businesses
 - Financial Records or other business secrets not yet made public which gives competitive advantage
 - National security for countries and governments

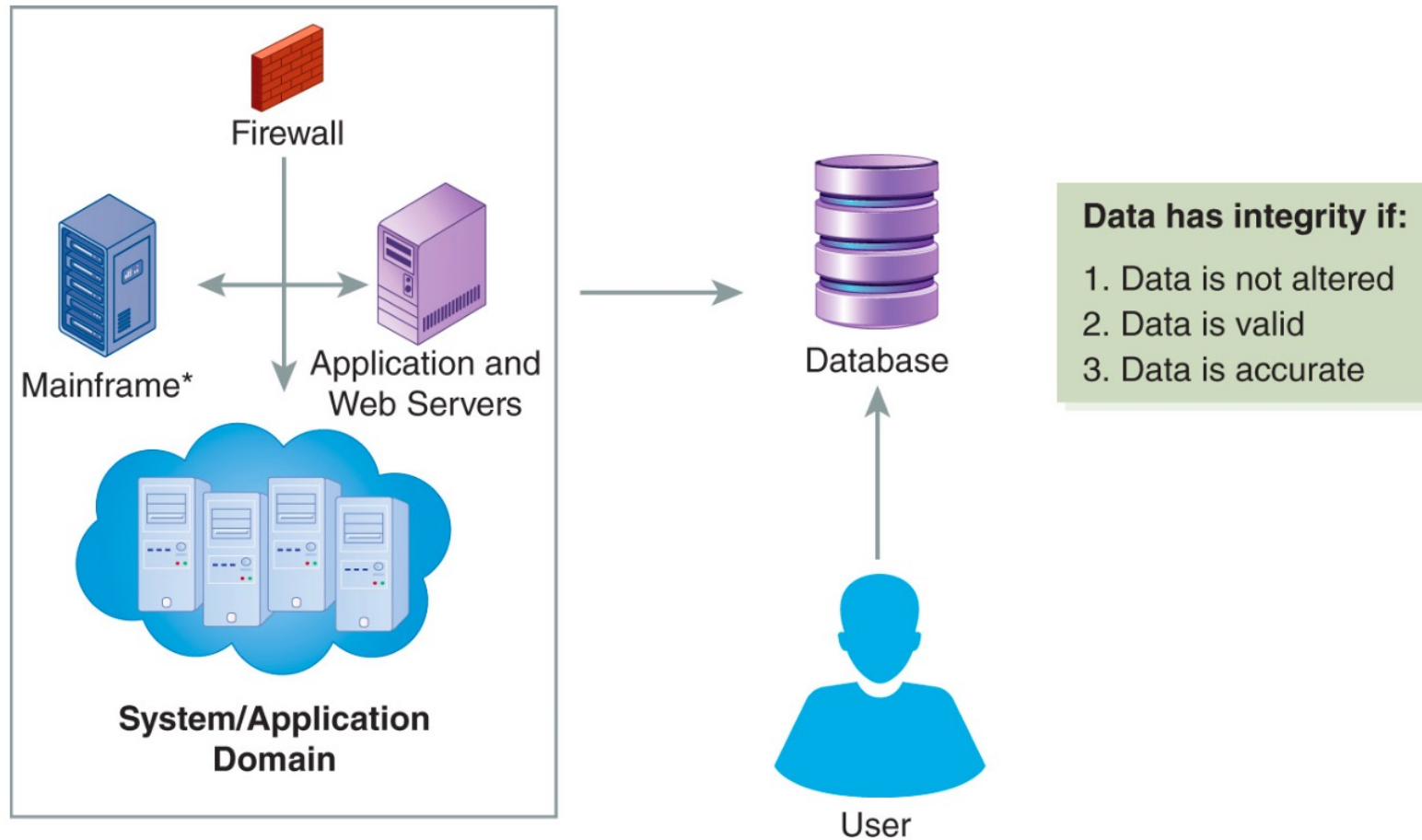
Confidentiality Controls



- Defining organization-wide policies, standards, procedures, and guidelines to protect confidential data.
- Adopting a **data classification standard** that defines how to treat data throughout the IT infrastructure, which is the road map for identifying what controls are needed to keep data safe.
- Limiting access to systems and applications that house confidential data to only those authorized to use that data.
- Using cryptography techniques to hide confidential data and keep it inaccessible to unauthorized users.
- Encrypting data that crosses the public Internet.
- Encrypting data that is stored within databases and storage devices.

Integrity

- Data integrity is the overall accuracy, completeness, and consistency of data



*Note: Used for bulk data processing requiring massive throughput

FIGURE 1-8 Data integrity

Integrity Controls

- Limiting access to data and changing permissions to restrict changes to information by unauthorized parties
- Validating data to make sure it's correct both when it's gathered and when it's used
- Backing up data
- Using logs to keep track of when data is added, modified, or deleted
- Conducting regular internal audits
- Using error-detection software
- Anti-malware systems or XDR

Availability



- Availability is the characteristic of being able to use the information system or data when and where it is required
- Invokes the term of uptime and downtime
- Very critical, especially for business processes

Availability Controls

- Intrusion detection systems (IDS)
- Intrusion Prevention Systems (IPS)
- Contingency Planning
 - Business continuity planning and testing
 - Data backup and restore
- XDR systems
- Service Level Agreements (SLA)

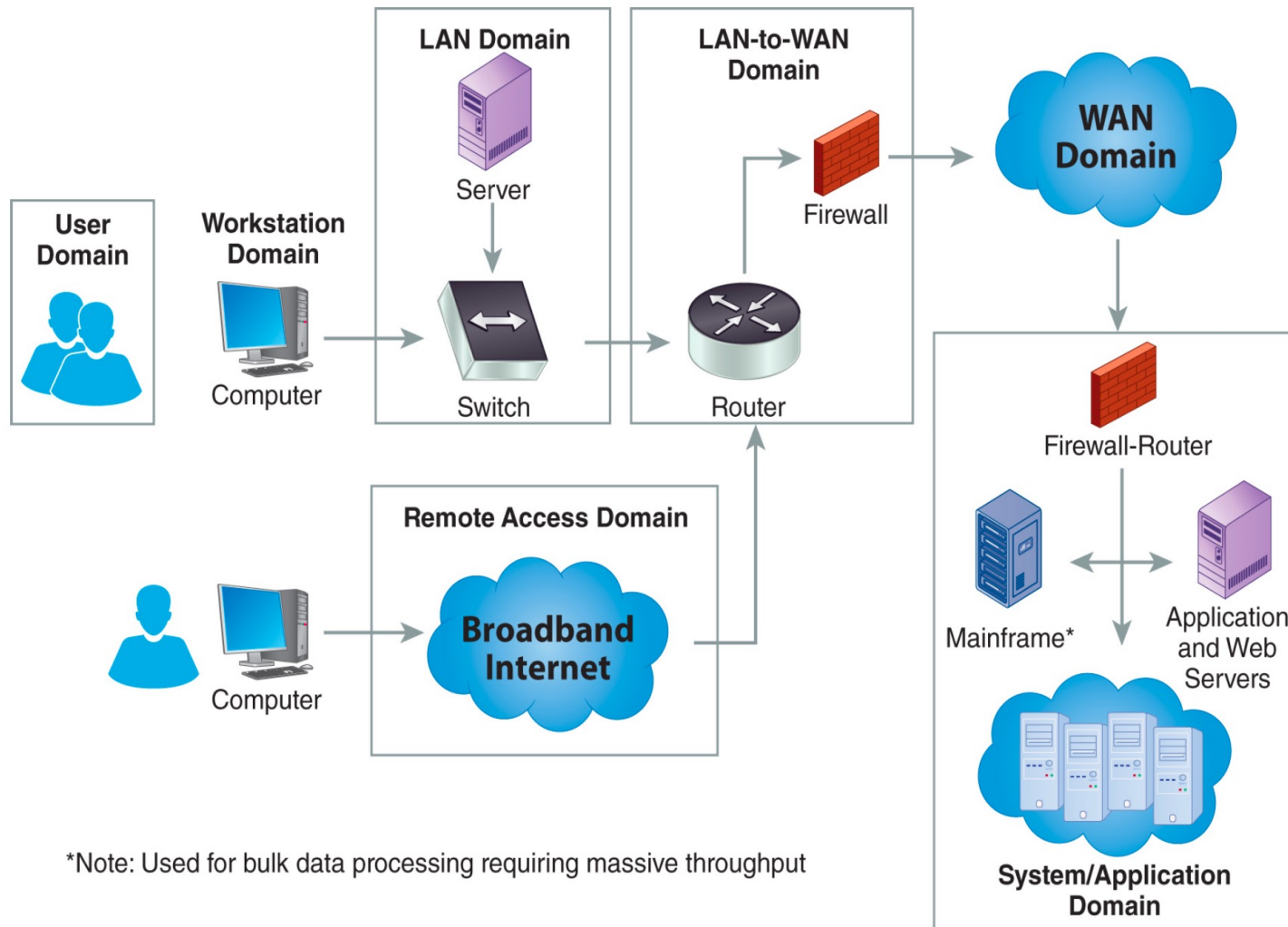


FIGURE 1-9 The seven domains of a typical IT infrastructure

Seven Domains of IT Infrastructure

User Domain



RISK, THREAT, OR VULNERABILITY	MITIGATION
Unauthorized access	Users must be made aware of phishing emails, pretexting or cons, keyboard loggers, and perpetrators impersonating an IT or delivery person in an attempt to obtain logon ID and password credentials.
Lack of user awareness	Conduct security awareness training, display security awareness posters, insert reminders in banner greetings, and send email reminders to employees.
User apathy toward policies	Conduct annual security awareness training, implement AUP, update staff manual and handbook, discuss during performance reviews.
Security policy violations	Place employee on probation, review AUP and employee manual, discuss during performance reviews.
User insertion of CD/DVDs and USB drives with personal photos, music, and videos	Disable internal CD/DVD drives and USB ports. Enable automatic antivirus scans for inserted media drives, files, and email attachments. An antivirus scanning system examines all new files on a computer's hard drive for viruses. Set up antivirus scanning for emails with attachments.
User downloads of photos, music, and videos	Enable content filtering and antivirus scanning for email attachments. Content-filtering network devices are configured to permit or deny specific domain names in accordance with AUP definitions.

Workstation Domain



RISK, THREAT, OR VULNERABILITY	MITIGATION
Unauthorized access to workstation	Enable password protection on workstations for access. Enable auto screen lockout for inactive times. Disable system administration rights for users.
Unauthorized access to systems, applications, and data	Define strict access control policies, standards, procedures, and guidelines. Implement a second level or layer of authentication to applications that contain sensitive data (e.g., two-factor authentication).
Desktop or laptop computer operating system software vulnerabilities	Define a workstation operating system vulnerability window policy and standard. The vulnerability window is the time from when a workstation is exposed to a known vulnerability until it is patched. Perform frequent vulnerability assessment scans as part of ongoing security operations.
Desktop or laptop application software vulnerabilities and software patch updates	Define a workstation application software vulnerability window policy. Update application software and security patches according to defined policies, standards, procedures, and guidelines.
Infection of a user's workstation or laptop computer by viruses, malicious code, or malware	Use workstation antivirus and malicious code policies, standards, procedures, and guidelines. Enable an automated antivirus protection solution that scans and updates individual workstations with proper protection.
User insertion of CDs/DVDs or USB thumb drives into the organization's computers	Deactivate all CD/DVD and USB ports. Enable automatic antivirus scans for inserted CDs/DVDs and USB thumb drives that have files.

LAN Domain

RISK, THREAT, OR VULNERABILITY	MITIGATION
Unauthorized access to LAN	Make sure wiring closets, data centers, and computer rooms are secure. Do not allow anyone access without proper ID.
Unauthorized access to systems, applications, and data	Define strict access control policies, standards, procedures, and guidelines. Implement a second-level identity check to gain access to sensitive systems, applications, and data. Restrict users from access to LAN folders and read, write, and delete privileges on specific documents as needed.
LAN server operating system software vulnerabilities	Define server, desktop, and laptop vulnerability window policies, standards, procedures, and guidelines. Conduct periodic LAN Domain vulnerability assessments to find software gaps. A vulnerability

LAN-to-WAN Domain



RISK, THREAT, OR VULNERABILITY	MITIGATION
Unauthorized network probing and port scanning	Disable ping, probing, and port scanning on all exterior IP devices within the LAN-to-WAN Domain. Ping uses the Internet Control Message Protocol (ICMP) echo-request and echo-reply protocol. Disallow IP port numbers used for probing and scanning and monitor with IDS/IPS.
Unauthorized access through the LAN-to-WAN Domain	Apply strict security monitoring controls for intrusion detection and prevention. Monitor for inbound IP traffic anomalies and malicious-intent traffic. Block traffic immediately if malicious.
Denial of service (DoS)/distributed denial of service (DDoS) attacks on external public-facing IPs and Internet links	Upstream Internet service providers (ISPs) must participate in DoS/DDoS attack prevention and discarding of IP packets when a stream of half-open TCP synchronize (SYN) packets start to flood the ISP link.

WAN Domain



RISK, THREAT, OR VULNERABILITY	MITIGATION
Open, public, easily accessible to anyone who wants to connect	Apply AUPs in accord with the document “RFC 1087: Ethics and the Internet.” Enact new laws regarding unauthorized access to systems, malicious attacks on IT infrastructures, and financial loss due to malicious outages.
Most Internet traffic sent in cleartext	Prohibit using the Internet for private communications without encryption and VPN tunnels. If you have a data classification standard, specifically follow its policies, procedures, and guidelines.
Vulnerable to eavesdropping	Use encryption and VPN tunnels for end-to-end secure IP communications. If you have a data classification standard, specifically follow its policies, procedures, and guidelines.
Vulnerable to malicious attacks	Deploy layered LAN-to-WAN security countermeasures, DMZ with IP stateful firewalls, IDS/IPS for security monitoring, and quarantining of unknown email file attachments.

Remote Access Domain



RISK, THREAT, OR VULNERABILITY	MITIGATION
Maximizing WAN performance and throughput	Apply WAN optimization and data compression solutions when accessing remote systems, applications, and data. Enable ACLs on outbound router WAN interfaces in keeping with policy.
Using SNMP network management applications and protocols maliciously (e.g., ICMP, Telnet, SNMP, and DNS)	Create separate WAN network management VLANs. Use strict firewall ACLs that allow SNMP manager and router IP addresses through the LAN-to-WAN Domain.
SNMP alarms and security monitoring 24/7/365	Outsource security operations and monitoring. Expand services to include managed security.
Maintaining high WAN service availability	Obtain WAN service availability SLAs. Deploy redundant Internet and WAN connections when 100 percent availability is required.

System/Application Domain



RISK, THREAT, OR VULNERABILITY	MITIGATION
Brute-force user ID and password attacks	Establish user ID and password policies requiring periodic changes (i.e., every 30 or 60 days). Passwords must be used, and they must have more than eight characters and include numbers and letters.
Multiple logon retries and access control attacks	Set automatic blocking for attempted logon retries (e.g., block user access after three logon attempts have failed).
Unauthorized remote access to IT systems, applications, and data	Apply first-level (i.e., user ID and password) and second-level (i.e., tokens, biometrics, and smart cards) security for remote access to sensitive systems, applications, and data.
Private or confidential data compromised remotely	Encrypt all private data within the database or hard drive. If data is stolen, the thief cannot use or sell it because it will be encrypted.
Data leakage in violation of existing data classification standards	Apply security countermeasures in the LAN-to-WAN Domain, including data leakage security-monitoring tools and tracking, as per the organization's data classification standard.

Weakest Link in the Security of an IT Infrastructure



- The human is the weakest link in security.
- Human error is a major risk and threat to any organization.
- Every organization must be prepared for malicious users, untrained users, and careless users.

Weakest Link in the Security of an IT Infrastructure



- Check the background of each job candidate carefully.
- Evaluate each staff member regularly.
- Rotate access to sensitive systems, applications, and data among different staff positions.
- Apply sound application and software testing and review for quality.
- Regularly review security plans throughout the seven domains of a typical IT system.
- Perform annual security control audits.

IT Security Policy Framework



An IT security policy framework contains four main components:

- **Policy**—A policy is a short and written statement that the people in charge of an organization have set as a course of action or direction.
- **Standard**—A standard is a detailed written definition for hardware and software and how they are to be used. Standards ensure that consistent security controls are used throughout the IT system.
- **Procedures**—Procedures are written instructions for how to use policies and standards. They may include a plan of action for installation, testing, and auditing of security controls.
- **Guidelines**—A guideline is a suggested course of action for using the policies, standards, or procedures. Guidelines can be specific or flexible regarding use.

IT Security Policy Framework

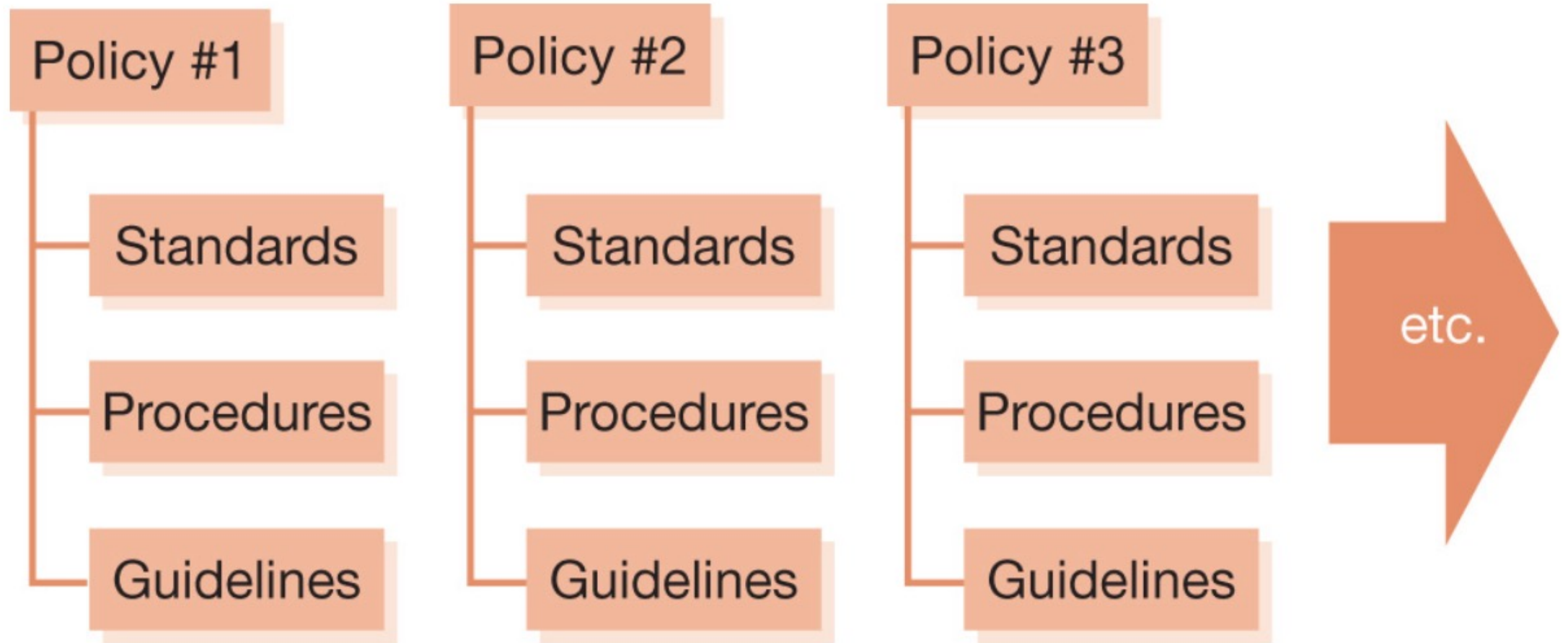


FIGURE 1-10 Hierarchical IT security policy framework

IT Security Policy Framework



- **Acceptable use policy (AUP)**—The AUP defines the actions that are and are not allowed regarding the use of organization-owned IT assets.
- **Security awareness policy**—This policy defines how to ensure that all personnel are aware of the importance of security and behavioral expectations under the organization's security policy.
- **Asset classification policy**—This policy defines an organization's data classification standard.
- **Asset protection policy**—This policy helps organizations define a priority for mission-critical IT systems and data.
- **Asset management policy**—This policy includes the security operations and management of all IT assets within the seven domains of a typical IT infrastructure.
- **Vulnerability assessment and management**—This policy defines an organization-wide vulnerability window for production operating system and application software.
- **Threat assessment and monitoring**—This policy defines an organization-wide threat assessment and monitoring authority.

Data Classification Standards - Private



- **Private** data—Data about people that must be kept private. Organizations must use proper security controls to be in compliance.
- **Confidential**—Information or data owned by the organization. Intellectual property, customer lists, pricing information, and patents are examples of confidential data.
- **Internal** use only—Information or data shared internally by an organization. Although confidential information or data may not be included, communications are not intended to leave the organization.
- **Public**-domain data—Information or data shared with the public, such as website content, white papers, and the like.

Data Classification Standards – Gov't



- **Top secret**—Applies to information that the classifying authority finds would cause grave damage to national security if it were disclosed.
- **Secret**—Applies to information that the classifying authority finds would cause serious damage to national security if it were disclosed.
- **Confidential**—Applies to information that the classifying authority finds would cause damage to national security.

Assignment



- Provide a list of at least 10 recent data breaches that has happened in 2023 around the world.
- Complete and submit the assessment



Thank You